

Actividad Asíncrona

Auditoría de Seguridad Web (Enfoque Frontend) con OWASP ZAP

El objetivo de esta actividad es instalar la herramienta OWASP ZAP, realizar un escaneo enfocado en la capa de presentación (Frontend) de su proyecto web, analizar el estado y nivel de riesgo de las alertas detectadas, aplicar medidas correctivas y verificar la mejora mediante un re-escaneo.

Fase 1: Preparación e Instalación

1. Descarga de la Herramienta: Para garantizar la compatibilidad y evitar problemas de versiones, diríjase a la sección de recursos del Aula Virtual y descargue el instalador oficial de OWASP ZAP que se encuentra allí alojado, tenga en cuenta descargar también el archivo JDK e instalarlo primero ya que esta herramienta es desarrollada en java por lo tanto necesita este complemento.
2. Instalación: Ejecute el instalador y siga los pasos indicados en pantalla (es necesario que cuente con Java instalado en su equipo, en los instaladores está un jdk).
3. Despliegue de su Proyecto: Asegúrese de que el entorno local (Frontend) de su sistema web se encuentre en ejecución y accesible (por ejemplo, navegando a <http://localhost:3000> o <http://127.0.0.1:8080> en su navegador).

Fase 2: Escaneo Rápido del Frontend

1. Abra la aplicación OWASP ZAP.
2. En la pantalla principal, seleccione la opción "Automated Scan" (Escaneo Automatizado).
3. En el campo denominado "URL to attack", introduzca la dirección web local correspondiente al frontend de su proyecto.
4. Haga clic en "Attack". Observe cómo la herramienta comienza a realizar peticiones automatizadas y pruebas de seguridad sobre la interfaz de su aplicación. Espere a que el progreso finalice.

Fase 3: Análisis y Selección de Alertas

Una vez concluido el escaneo, ubique la pestaña "Alerts" (Alertas) en el panel inferior de la interfaz. En esta sección visualizará una lista de hallazgos clasificados por colores según su severidad (Rojo: Alto, Naranja: Medio, Amarillo: Bajo, Azul: Informativo).

1. Filtro de Resultados: Enfóquese exclusivamente en aquellas alertas relacionadas con el lado del cliente y la configuración del navegador (por ejemplo: falta de cabeceras de seguridad como *X-Frame-Options* o *X-Content-Type-Options*, problemas con *Cookies*, o posibles vulnerabilidades *Cross Site Scripting - XSS*).
2. Selección de Riesgos: Analice los resultados y seleccione tres (3) alertas específicas que procederá a corregir.
3. Lea detenidamente la descripción de la alerta y la sección "Solution" (Solución) que la misma herramienta OWASP ZAP le sugiere para mitigar el problema.

Fase 4: Remediación en el Código

Con base en las tres alertas seleccionadas y las sugerencias brindadas por la herramienta:

1. Diríjase al código fuente de su proyecto web o a los archivos de configuración de su servidor de desarrollo.
2. Aplique los cambios necesarios para resolver cada una de las tres vulnerabilidades. (Ejemplo: agregar etiquetas <meta> en su HTML, configurar cabeceras en su framework, etc.).
3. Guarde los cambios y asegúrese de que su proyecto siga funcionando correctamente.

Fase 5: Verificación (Re-escaneo)

El ciclo de seguridad exige comprobar que las medidas aplicadas fueron efectivas.

1. Regrese a OWASP ZAP y vuelva a ejecutar un "Automated Scan" sobre la misma URL inicial.
2. Al finalizar, revise nuevamente la pestaña de "Alerts".
3. Verifique que las tres vulnerabilidades que usted intervino ya no se encuentren en la lista, o que su etiqueta de riesgo haya disminuido significativamente.

Requisitos del Entregable Final

Usted deberá elaborar y subir al Aula Virtual un Informe Técnico de Remediación en formato PDF. El informe debe estar estructurado presentando cada uno de los 3 riesgos seleccionados por separado.

Por cada uno de los tres riesgos, usted debe incluir obligatoriamente las siguientes tres evidencias:

Riesgo 1: [Nombre de la vulnerabilidad, ej. Ausencia de X-Frame-Options]

- Evidencia 1 (Problema): Captura de pantalla del primer escaneo en OWASP ZAP donde se observe claramente la alerta seleccionada, su nivel de riesgo y la descripción.
- Evidencia 2 (Solución).- Captura de pantalla de su editor de código fuente mostrando la línea o bloque de código exacto que usted modificó o añadió para solucionar el hallazgo.
- Evidencia 3 (Verificación).-Captura de pantalla del segundo escaneo (re-escaneo) en OWASP ZAP, demostrando que la alerta específica ha desaparecido o que su estado ha sido mitigado de forma exitosa.

(Repita esta misma estructura de tres capturas para el Riesgo 2 y el Riesgo 3).